GROGO□I.MARKET

Trusted Identity Execution Layer

Implementation Supplement: Closing the Architecture Gaps

Version 1.0 | June 2026 | CONFIDENTIAL

The TIEL core architecture document defines a robust cryptographic identity model for Grogoni. This supplement addresses four implementation gaps identified in the initial specification: hardware trust degradation on low-end devices, key recovery without re-centralising trust, the Identity Authority as a single point of failure, and offline-first operation. For each gap, this document provides design decisions, implementation guidance, and acceptance criteria.

1. Hardware Trust Degradation

The TIEL specification defines five device trust levels (0–4). In practice, a significant proportion of the Grogoni target audience — merchants and suppliers in emerging markets — operates on devices that support only Level 0 (software-only storage). This creates a gap between the security model and the deployed reality.

1.1 Threat Model by Level

Trust Level	Threat Resistance Profile
Level 0	Software-only. Keys in encrypted app storage. Vulnerable to device compromise, root access, and memory scraping.
Level 1	Hardware Keystore. Keys protected by OS-enforced hardware boundary. Resistant to app-layer attacks.
Level 2	TEE (TrustZone / Secure Enclave). Keys never exposed to main OS. Resistant to OS compromise.
Level 3	Dedicated Secure Element. Tamper-resistant hardware. Resistant to physical attack.
Level 4	Certified TIM. Formally evaluated SE with attestation. Highest assurance.

1.2 Compensating Controls for Level 0

Where hardware security is unavailable, the platform must compensate with layered software controls rather than simply accepting reduced security silently.

- Encrypted key vault: AES-256-GCM with key derived from device-specific entropy (Android ID, hardware serial hash) combined with user PIN via PBKDF2 (310,000 iterations minimum).
- Binding to device fingerprint: Key decryption requires a match against stored device fingerprint. Export to another process or device fails silently.
- Jailbreak / root detection: On detected compromise, downgrade identity to read-only mode and alert the Identity Authority.
- Short-lived session tokens: Level 0 sessions expire after 4 hours. Level 2+ sessions may extend to 24 hours.
- Operation gating: Sensitive operations (high-value payments, supplier contract signing) require Level 1 minimum. Operators may raise the threshold per-operation.

Design Decision

The platform must never silently accept Level 0 for sensitive operations. The identity profile must declare its trust level, and the requesting service must enforce minimum trust requirements. Failure must surface to the user with a clear upgrade path, not degrade invisibly.

1.3 Trust Level Upgrade Path

Merchants and suppliers on Level 0 devices must be guided toward higher trust levels through a progressive upgrade model:

- In-app prompt: When a Level 0 device attempts a gated operation, display a guided workflow to enable hardware keystore (Android 9+ supports this on most mid-range devices).
- Device recommendation: Provide a minimum device specification for Level 2 support, referenced in the merchant onboarding documentation.
- Incentive model: Consider commercial incentives (reduced transaction fees, higher withdrawal limits) for merchants operating at Level 2 or above.

2. Key Recovery Without Re-Centralising Trust

Hardware-backed keys that never leave the device are the correct security model. However, this creates a catastrophic failure mode: if a device is lost, stolen, or destroyed, the user's identity is permanently unrecoverable unless a recovery mechanism exists. Naive recovery mechanisms re-centralise trust, defeating the architecture.

2.1 Recovery Threat Model

Any recovery mechanism must be evaluated against two opposing risks:

Mechanism	Trade-offs
Custodial recovery	IA or operator holds recovery key. Simple UX, but reintroduces central trust. IA compromise exposes all identities.

No recovery	Maximum security. Catastrophic UX. Unacceptable for commerce platform.
Social recovery	User-nominated guardians hold key shards. No central custodian. Requires guardians to be available.
Threshold cryptography	Key shards split across user-controlled devices + IA. Recovery requires quorum. Balanced model.
Encrypted backup	User exports encrypted key blob to cloud. IA holds no key material. User controls recovery password.

2.2 Recommended Approach: Threshold Recovery

TIEL should implement a 2-of-3 threshold recovery scheme combining:

- Shard A: Derived from user's recovery passphrase (never transmitted).
- Shard B: Stored in user's cloud account (Google Drive / iCloud), encrypted with Shard A.
- Shard C: Held by the Identity Authority, encrypted with the user's public key at registration time.

Recovery requires any two of the three shards. The IA alone cannot recover the key (it holds Shard C but not A or B). The user alone cannot recover without either cloud access or the IA.

> **Security Property**
> The IA holding Shard C without Shard A means a compromised IA cannot unilaterally recover any user identity. This preserves the decentralised trust model while providing a practical recovery path.

2.3 Recovery Flow

Step	Description
1. Initiation	User declares device lost via secondary authenticated channel (email OTP to registered address, or guardian approval).
2. Shard assembly	User provides recovery passphrase (Shard A). Platform fetches encrypted Shard B from cloud storage. IA releases Shard C after verifying identity via secondary channel.
3. Key reconstruction	Client-side only: shards combined using Shamir Secret Sharing to reconstruct the original private key.
4. Re-provisioning	Reconstructed key installed in new device TIM. Old device identity flagged as revoked in IA registry.
5. Audit	Full recovery event logged with timestamp, channel used, and new device fingerprint.

2.4 Guardian-Based Social Recovery (Optional)

For high-value identities (large merchants, suppliers), offer an additional social recovery path. The user nominates 3–5 trusted contacts (guardians) during onboarding. A 3-of-5 quorum of guardians can authorise identity recovery without IA involvement. Guardian identities must themselves be at Level 1 or above.

3. Identity Authority as Single Point of Failure

The Identity Authority (IA) is the root of trust for the entire network. As specified, it performs identity issuance, credential rotation, revocation, and challenge verification. This concentration creates both a security target and an availability risk.

3.1 Failure Modes

- Availability: IA outage prevents new identity provisioning and blocks challenge-response authentication for online operations.
- Security: A compromised IA could issue fraudulent identities, revoke legitimate ones, or intercept challenge-response flows.
- Governance: Operator control of the IA creates a trust dependency for all participants.

3.2 Federated IA Architecture

Replace the single IA with a federated model consisting of:

- Root IA: Air-gapped HSM cluster. Issues certificates to Regional IAs only. Never directly accessible from the internet. Operated under multi-party control (requires M-of-N operator quorum for any operation).
- Regional IAs: Online nodes responsible for provisioning, authentication, and revocation within a geographic or organisational domain. Each is cross-certified by the Root IA.
- Local IA Cache: Read-only replica of the certificate revocation list (CRL) and public key registry, deployable on-premises or at the network edge for offline operation.

Governance Model

The Root IA should be operated under a formal governance structure with defined key ceremony procedures, HSM custody policies, and multi-party signing requirements. Consider a model analogous to a Certificate Authority's root key ceremony, documented and auditable.

3.3 IA Compromise Response

Scenario	Response
Detection	All IA operations signed and logged. Anomaly detection on issuance rate, revocation patterns, and geographic distribution of requests.
Containment	Compromised Regional IA can be revoked by Root IA. Affected identities flagged for re-issuance.

Recovery	New Regional IA provisioned from Root IA. Participants re-authenticate via alternative Regional IA. Recovery documented in audit log.
Root IA compromise	Requires full root key ceremony. All participant certificates must be re-issued. Highest-severity event with defined incident response runbook.

3.4 IA Availability SLA

Regional IAs should be deployed with:

- Minimum 3 nodes per region in an active-active configuration.
- Health check interval: 10 seconds. Automatic failover: 30 seconds.
- Target availability: 99.95% per region.
- CRL distribution: pushed to all Local IA Caches every 5 minutes.

4. Offline-First Operation

The TIEL authentication flow as specified requires the Identity Authority to issue a challenge and verify the response. This is incompatible with offline operation, which is a stated requirement for Grogoni's target markets where connectivity is intermittent.

4.1 Offline Authentication Model

Offline authentication must satisfy three properties: it must not require IA connectivity, it must be cryptographically verifiable when connectivity is restored, and it must expire to bound the risk of operating on a stale revocation state.

Recommended approach: Offline Session Tokens (OSTs).

- At last successful online authentication, the IA issues a signed Offline Session Token.
- The OST contains: identity GIID, trust level, permission set snapshot, issue timestamp, expiry timestamp, and IA signature.
- The OST is stored in the local TIM. While offline, the device verifies the OST locally using the IA's public key (pre-installed and pinned).
- All operations performed under an OST are recorded in a local tamper-evident operation log.
- On reconnection, the operation log is submitted to the IA for validation and the OST is refreshed.

4.2 OST Expiry and Risk Calibration

Operation Class	Offline Policy

Low-value operations(browse, small purchases)	OST validity: 72 hours. Acceptable risk: low.
Medium-value operations(supplier orders)	OST validity: 24 hours. Requires Level 1+.
High-value operations(contract signing, large payments)	OST validity: 4 hours. Blocked if OST expired. Requires Level 2+.
Identity management(profile changes, key rotation)	Online only. Cannot be performed under OST.

4.3 Conflict Resolution

When operation logs from multiple offline periods are submitted to the IA, conflicts may arise (e.g. the same inventory item sold twice on two devices). Resolution rules:

- Timestamp ordering: Operations are applied in chronological order where no conflict exists.
- Conflict flagging: Conflicting operations are flagged for human review rather than automatically resolved.
- Identity revocation precedence: If a revocation was issued during an offline period, all operations performed by that identity after the revocation timestamp are voided and the affected counterparties notified.

Offline Revocation Gap

The most significant residual risk is a device operating on an OST after its identity has been revoked (e.g. due to fraud detection). This risk is bounded by the OST expiry window. For high-risk deployments, consider a peer-to-peer revocation gossip protocol that propagates revocation events between nearby devices via Bluetooth or local Wi-Fi mesh, reducing the effective revocation propagation delay without requiring internet connectivity.

4.4 Local IA Cache

Where an operator controls local infrastructure (a warehouse, a market, a distribution hub), a Local IA Cache node should be deployed. The cache:

- Maintains a current copy of the certificate revocation list, synced when internet is available.
- Serves OST validation requests from nearby devices over local network.
- Buffers operation logs for batch submission when connectivity is restored.
- Does not issue identities or perform key operations — read-only trust role only.

5. Implementation Roadmap

The gaps addressed in this document should be resolved in sequence, as each builds on the previous:

Phase	Scope
Phase 1 (Months 1–3)	Implement trust level detection and operation gating. Deploy compensating controls for Level 0. Establish minimum device specification.
Phase 2 (Months 2–4)	Design and implement threshold key recovery. Integrate with cloud storage providers. Document and test guardian recovery path.
Phase 3 (Months 3–6)	Federate the Identity Authority. Implement Root IA governance procedures. Deploy Regional IAs with failover.
Phase 4 (Months 4–8)	Implement Offline Session Tokens. Define OST expiry policy per operation class. Build and test conflict resolution logic.
Phase 5 (Months 6–12)	Pilot Local IA Cache at select merchant hubs. Evaluate peer-to-peer revocation gossip. Harden based on field data.

6. Acceptance Criteria

The following criteria define successful closure of each gap:

Hardware Trust Degradation

- Operation gating enforced: high-value operations blocked on Level 0 devices.
- Trust level declared in every authentication token and verifiable by relying parties.
- Level 0 compensating controls pass independent security review.

Key Recovery

- 2-of-3 threshold recovery implemented and tested end-to-end.
- IA cannot unilaterally recover any identity without user-held shard.
- Recovery event produces complete audit trail.
- Recovery UX tested with representative users in target markets.

Identity Authority Resilience

- Federated IA deployed with minimum 3 Regional IA nodes.
- Root IA air-gapped and operating under documented multi-party governance.
- IA availability meets 99.95% SLA over 90-day measurement period.
- Regional IA compromise response tested via tabletop exercise.

Offline Operation

- OST issued at end of every successful online authentication session.
- Offline operation validated against OST without IA connectivity.
- Operation log submitted and validated on reconnection.
- Conflict resolution logic tested against defined scenarios.
- Revocation propagation delay bounded and documented per trust level.

End of Supplement